VULNERABILITY ASSESSMENT REPORT

Penetration Test di laboratorio — Host Metasploitable 2

RISCHIO CRITICO

Data:	7 Maggio 2025 (revisione formale: 23 Ottobre 2026)
Versione:	1.2 (Definitiva)
Redatto da:	Charaf Mansori
Target:	192.168.50.2 — Metasploitable 2
Contesto:	Scenario didattico, ambiente di laboratorio isolato

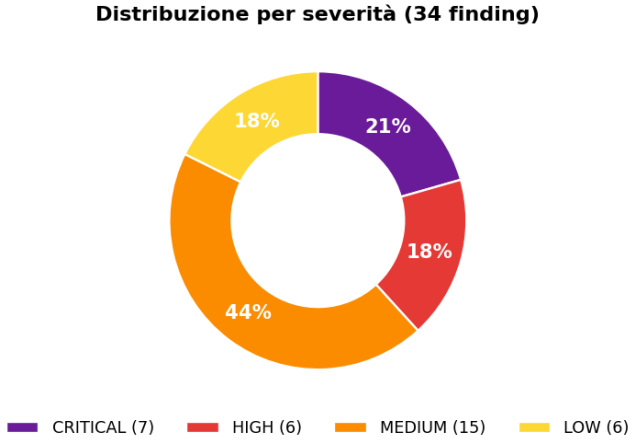
INDICE

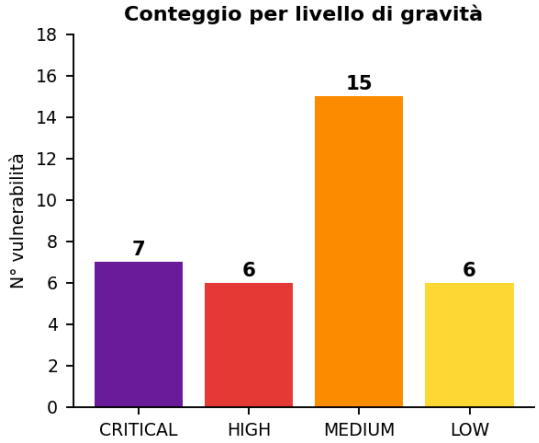
1.	Sommario Esecutivo
2.	Dettagli dell'Incarico
3.	Ambiente di Test
4.	Strumenti Utilizzati
5.	Versioni e Revisioni del Documento
6.	Metodologia
7.	Rilevamenti Principali
8.	Analisi dell'Impatto
9.	Raccomandazioni Prioritarie
10.	Timeline di Implementazione
11.	Conclusioni
12.	Appendici

1. Sommario Esecutivo

Il presente documento riporta l'esito di un vulnerability assessment e penetration test svolto in **laboratorio** su un host **Metasploitable 2** (IP 192.168.50.2), una macchina virtuale volutamente vulnerabile. Lo scenario simula il ritrovamento di un sistema non autorizzato all'interno della rete di un'azienda (cliente fittizio). La scansione con **Nessus Essentials**, integrata da enumerazione con Nmap e verifica manuale con Metasploit, ha evidenziato una postura di sicurezza totalmente assente: rischio complessivo **CRITICO**.

Livello di gravità	CVSS	Conteggio
CRITICAL	9.0 – 10.0	7
HIGH	7.0 – 8.9	6
MEDIUM	4.0 – 6.9	15
LOW	0.1 – 3.9	6
Totale		**34**





2. Dettagli dell'Incarico

Parametro	Dettaglio
Committente	Cliente fittizio (scenario didattico)
Obiettivo	Confermare identità host, mappare superficie di attacco, valutare impatto
Target	192.168.50.2 (Metasploitable 2 / Ubuntu 8.04, fine supporto)
Finestra test	Maggio 2025

3. Ambiente di Test

Componente	Dettaglio
Piattaforma di attacco	Kali Linux 2023.2 su Oracle VirtualBox (IP 192.168.50.1)
Piattaforma target	Metasploitable 2 / Ubuntu 8.04 (supporto server terminato nel 2013)
Indirizzo IP target	192.168.50.2
Rete	Rete host-only isolata, nessuna connessione verso sistemi reali

4. Strumenti Utilizzati

Strumento	Versione	Finalità	Vendor/Autore
Nessus Essentials	10.x	Vulnerability scanning	Tenable Inc.
Nmap	7.94	Host discovery / port scan	Gordon Lyon
Kali Linux	2023.2	Piattaforma di attacco	Offensive Security
Metasploit Framework	6.3.x	Exploitation / PoC	Rapid7
Oracle VirtualBox	7.0	Virtualizzazione lab	Oracle Corp.
Wireshark	4.0.x	Network traffic analysis	Wireshark Foundation
Netcat (nc)	1.10-47	Reverse shell / port check	Hobbit / OpenBSD
Hydra	9.4	Credential bruteforce	van Hauser / THC

5. Versioni e Revisioni del Documento

Versione	Data	Autore	Modifiche	Stato
1.0	06/05/2025	Charaf Mansori	Bozza iniziale	Revisione interna
1.1	07/05/2025	Charaf Mansori	Aggiunta sezione RPC e Backdoor	Definitiva
1.2	23/10/2026	Charaf Mansori	Correzioni formali (date, versioni OS, grafici, terminologia)	Definitiva

6. Metodologia

L'attività è stata condotta seguendo le fasi canoniche di un penetration test:

Fase	Descrizione
Host Discovery	Scansione della rete per l'individuazione di asset attivi
Service Detection	Enumerazione dei servizi e delle porte aperte (Nmap)
Vulnerability Scanning	Analisi automatizzata con Nessus Essentials (CVSS v3.0)
Exploitation (PoC)	Verifica manuale della sfruttabilità (es. accesso FTP, shell remota)
Analisi dell'impatto	Valutazione del rischio per il business

7. Rilevamenti Principali

7.1 — Remote Shell Access (RCE)	CRITICAL | CVSS 10.0
Famiglia	Gain Shell Remotely / General
Descrizione	Identificate 3 istanze distinte che permettono l'acquisizione di una shell remota. La vulnerabilità consente a un attaccante non autenticato di assumere il controllo totale del sistema con privilegi elevati (root).
Raccomandazione	Decommissionare l'host. Non esistono patch applicabili a un sistema strutturalmente compromesso.

7.2 — Backdoor e Vulnerabilità Web	CRITICAL | CVSS 9.8
Famiglia	Backdoors / Web Servers
Descrizione	Il sistema espone backdoor note e servizi web obsoleti che consentono l'accesso bypassando ogni forma di controllo. Essendo Ubuntu 8.04 fuori supporto, non è possibile applicare misure di sicurezza moderne.
Raccomandazione	Disabilitare subito l'interfaccia di rete del target.

7.3 — Esposizione Servizi RPC	HIGH | CVSS 7.5
Famiglia	Service Detection / RPC
Descrizione	I servizi RPC forniscono informazioni sulla configurazione interna, facilitando l'enumerazione di utenti e condivisioni di rete.
Raccomandazione	Regole di firewalling restrittive per bloccare il traffico RPC non necessario.

7.4 — Service Detection	HIGH | CVSS 7.5
Famiglia	Service Detection
Descrizione	Il sistema ha risposto a tecniche di service fingerprinting e banner grabbing, esponendo informazioni dettagliate sulle applicazioni in ascolto (oltre alla semplice apertura delle porte).
Raccomandazione	Implementare un firewall o una ACL; ridurre i banner esposti.

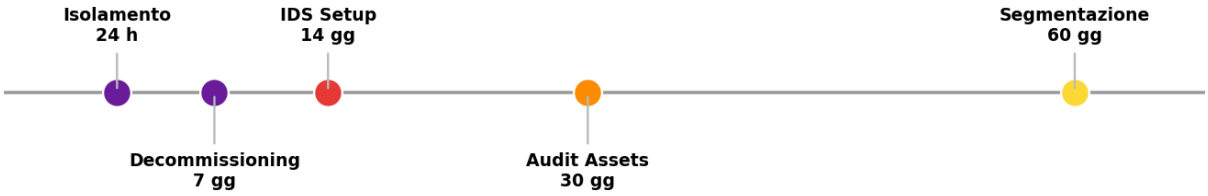
8. Analisi dell'Impatto

Rischio	Livello	Dettaglio
Probabilità di compromissione	CRITICA	Host privo di difese attive, con sistema operativo fuori supporto.
Rischio di pivot (lateral movement)	CRITICO	Assenza di egress filtering; FTP con credenziali di default.
Perdita di integrità dei dati	ALTA	Accesso root senza autenticazione.
Interruzione dei servizi	ALTA	Compromissione completa del sistema.
Esposizione credenziali	ALTA	Servizi in chiaro (FTP/Telnet).

9. Raccomandazioni Prioritarie

#	Azione	Priorità	Scadenza	Responsabile	Descrizione
1	Isolamento immediato	CRITICA	24 ore	Network / IT Mgr	Isolare logicamente via ACL l'host 192.168.50.2.
2	Decommissioning	CRITICA	7 giorni	Asset Mgr / CTO	Spegnimento permanente; rimozione di FTP/Telnet/Rsh.
3	Monitoraggio attivo (IDS)	ALTA	14 giorni	SOC / SecOps	Configurare IDS e alert per scansioni anomale e traffico sospetto.
4	Audit di configurazione	MEDIA	30 giorni	Infra Team	Audit della rete per asset EOL; policy di gestione del ciclo di vita.
5	Segmentazione di rete	MEDIA	60 giorni	Net Architect / CTO	VLAN separate per lab / sviluppo / produzione / management.

10. Timeline di Implementazione



Fase	Scadenza	Priorità	Stato
Isolamento	24 ore	CRITICAL	Da fare
Decommissioning	7 giorni	CRITICAL	Da fare
IDS Setup	14 giorni	HIGH	Da fare
Audit Assets	30 giorni	MEDIUM	Da fare
Segmentazione rete	60 giorni	MEDIUM	Da fare

11. Conclusioni

L'analisi conferma che Metasploitable 2 è una macchina vulnerabile *per design*: la sua presenza in un ambiente aziendale rappresenterebbe un errore di configurazione perimetrale gravissimo. Sistemi di questo tipo devono essere confinati esclusivamente in ambienti sandbox isolati, senza alcuna connettività verso il resto dell'infrastruttura.

Nello scenario simulato, la severità delle falle richiederebbe azioni immediate da parte del management: ogni ritardo espone l'organizzazione a rischi significativi di sicurezza e conformità normativa.

12. Appendici

12.A — Tabella Acronimi

Acronimo	Significato
VA	Vulnerability Assessment
PT	Penetration Test
CVSS	Common Vulnerability Scoring System
CVE	Common Vulnerabilities and Exposures
RCE	Remote Code Execution
RPC	Remote Procedure Call
FTP	File Transfer Protocol
IDS	Intrusion Detection System
ACL	Access Control List
EOL	End of Life
VLAN	Virtual Local Area Network
PoC	Proof of Concept
SOC	Security Operations Center

12.B — Definizioni

Termine	Definizione
Vulnerability Assessment	Scansione metodica e analisi sistematica di asset IT per identificare configurazioni errate, servizi non patchati e vulnerabilità note.
Penetration Test	Simulazione di attacco reale per valutare se le vulnerabilità identificate sono effettivamente sfruttabili.
CVSS Score	Punteggio standard (0–10) della severità: ≥ 9.0 CRITICAL, 7.0–8.9 HIGH, 4.0–6.9 MEDIUM, 0.1–3.9 LOW.
Remote Code Execution	Capacità di un attaccante di eseguire codice arbitrario su un sistema remoto, anche senza autenticazione.
Movimento laterale	Tecnica con cui un attaccante usa una macchina compromessa per raggiungere altri asset della rete.
Egress filtering	Policy di firewall che limita il traffico in uscita, impedendo ai sistemi compromessi di contattare attaccanti esterni.
End of Life (EOL)	Stato di un software o sistema operativo per cui il produttore non rilascia più aggiornamenti di sicurezza.